



STARIAX GROUP — European Tech Group

CHALLENGER

Protection des données personnelles

Cartographie des traitements, bases légales, sous-traitants,
droits des personnes et écarts de conformité

Référence	CIA-DOC-04
Version	1.0
Date d'émission	19 juillet 2026
Éditeur	STARIAX GROUP — European Tech Group
Produit	Challenger IA (challengeria.fr)
Classification	CONFIDENTIEL — Diffusion restreinte

Ce document contient des informations confidentielles et des secrets d'affaires appartenant à STARIAX GROUP — European Tech Group. Toute reproduction, diffusion ou communication à un tiers, totale ou partielle, est interdite sans autorisation écrite préalable.

1. Mentions légales et clause de confidentialité

1.1 Éditeur et titulaire des droits

STARIAX GROUP (European Tech Group), société éditrice, est titulaire de l'ensemble des droits de propriété intellectuelle portant sur le logiciel Challenger IA, sur sa documentation, sur son architecture, sur ses jeux d'instructions système et sur les marques et logos associés.

Challenger IA est un produit de STARIAX GROUP, exploité sous le nom de domaine challengeria.fr et distribué sous forme d'application web et d'applications mobiles natives iOS et Android (identifiant applicatif tech.stariax.challengeria).

1.2 Objet du document

Le présent document constitue la cartographie des traitements de données à caractère personnel opérés par Challenger IA, au sens du règlement (UE) 2016/679. Il recense les données collectées, leurs finalités, leurs bases légales, les destinataires, les durées de conservation et les mesures de sécurité, et identifie les écarts de conformité constatés.

Le présent document décrit un état du système à la date d'émission indiquée en couverture. Le logiciel étant en développement actif, certaines caractéristiques sont susceptibles d'évoluer. Toute divergence constatée entre ce document et le code source doit être résolue en faveur du code source, qui fait foi.

1.3 Clause de confidentialité

Ce document est classé CONFIDENTIEL. Il contient des informations techniques non publiques, des secrets d'affaires et des éléments constitutifs du savoir-faire de STARIAX GROUP, notamment les jeux d'instructions système, les algorithmes d'analyse cognitive et les mécanismes de notation des sources.

Sa communication est strictement réservée aux personnes ayant besoin d'en connaître dans le cadre de leurs fonctions ou d'une relation contractuelle avec STARIAX GROUP. Toute reproduction, représentation, diffusion, transmission ou mise à disposition d'un tiers, en tout ou partie et par quelque procédé que ce soit, est interdite sans autorisation écrite préalable de l'éditeur.

Le destinataire s'engage à prendre toutes mesures raisonnables pour préserver la confidentialité de ce document, à en restreindre l'accès et à le détruire ou le restituer sur simple demande de l'éditeur.

1.4 Protection au titre du secret des affaires

Les informations contenues dans ce document constituent des secrets d'affaires au sens de l'article L. 151-1 du Code de commerce et de la directive (UE) 2016/943 : elles ne sont pas généralement connues, elles revêtent une valeur commerciale du fait de leur caractère secret, et elles font l'objet de mesures de protection raisonnables de la part de leur détenteur légitime.

Leur obtention, utilisation ou divulgation illicite engage la responsabilité civile de son auteur et peut donner lieu à des mesures provisoires et conservatoires ainsi qu'à des dommages et intérêts.

1.5 Droit applicable et juridiction

Le présent document et les obligations de confidentialité qu'il emporte sont régis par le droit français. Tout litige relatif à son interprétation ou à son exécution relève de la compétence exclusive des tribunaux français compétents, nonobstant pluralité de défendeurs ou appel en garantie.

1.6 Limitation de responsabilité

Ce document est fourni à titre informatif. STARIAX GROUP ne garantit ni l'exhaustivité ni l'absence d'erreur de son contenu et ne saurait être tenu responsable des conséquences d'une utilisation qui en serait faite au-delà de sa finalité

documentaire.

Nature de ce document

Ce document est un état des lieux technique, établi par analyse du code source. Il constitue une base de travail pour l'élaboration du registre des activités de traitement prévu à l'article 30 du règlement, mais ne s'y substitue pas. Il recense volontairement les écarts de conformité constatés : leur identification est le préalable à leur correction. Une validation par un conseil juridique spécialisé est recommandée avant toute ouverture large du service.

Sommaire

1. Mentions légales et clause de confidentialité 2

1.1 Éditeur et titulaire des droits 2

1.2 Objet du document 2

1.3 Clause de confidentialité 2

1.4 Protection au titre du secret des affaires 2

1.5 Droit applicable et juridiction 2

1.6 Limitation de responsabilité 2

2. Responsable de traitement et périmètre 6

3. Cartographie des données collectées 7

3.1 Données d'identification 7

3.2 Contenu produit par l'utilisateur 7

3.3 Profil utilisateur déclaratif 7

3.4 Profil cognitif — données de profilage 8

3.5 Données transactionnelles et techniques 8

4. Finalités et bases légales 9

5. Destinataires et sous-traitants 10

5.1 Point de vigilance sur la recherche web 10

6. Durées de conservation 11

7. Droits des personnes 12

7.1 Écarts sur le droit à l'effacement 12

8. Mesures de sécurité 13

8.1 Mesures en place 13

8.2 Mesures absentes 13

9. Nécessité d'une analyse d'impact 14

10. Synthèse des écarts et plan de mise en conformité 15

10.1 Séquencement proposé 15

11. Historique du document 15

2. Responsable de traitement et périmètre

Élément	Valeur
Responsable de traitement	STARIAX GROUP — European Tech Group
Produit concerné	Challenger IA (challengeria.fr)
Supports	Application web, applications natives iOS et Android
Public visé	Utilisateurs majeurs, francophones
Délégué à la protection des données	À désigner — voir écart n° 9
Contact	contact@stariax.tech

Challenger IA traite des données à caractère personnel dans le cadre de la fourniture d'un service d'entraînement à la pensée critique. La particularité du traitement tient à deux éléments : le contenu des conversations est librement saisi et peut donc contenir toute nature d'information, et le produit réalise un profilage du raisonnement de l'utilisateur.

3. Cartographie des données collectées

3.1 Données d'identification

Donnée	Support	Emplacement
Identifiant utilisateur	Firebase Auth	Clé de tous les documents
Adresse électronique	Firebase Auth, Supabase	subscriptions, user_contacts, subscribers
Mot de passe (empreinte)	Firebase Auth	Géré par le fournisseur, jamais accessible à l'éditeur
Nom affiché et photographie	Firebase Auth	Renseignés par la connexion Google
Horodatages de connexion	Firebase Auth	Date de création et dernière connexion

Une connexion anonyme est proposée : elle permet l'usage du service sans communication d'adresse électronique.

3.2 Contenu produit par l'utilisateur

Donnée	Emplacement	Observation
Conversations complètes	Firestore, par utilisateur	Messages, titres, sources ; contenu libre
Pièces jointes textuelles	Firestore, dans la conversation	Tronquées à 8 000 caractères
Pièces jointes images	Non conservées	Transmises au modèle, non stockées
Dossiers de classement	Firestore, par utilisateur	Nom et couleur
Conversations partagées	Firestore, collection publique	Lecture accessible à toute personne disposant du lien
Sessions des outils métier	Stockage local du navigateur	Messages complets, non synchronisés

Le contenu conversationnel est imprévisible par nature

Un utilisateur soumettant une thèse à contradiction peut y intégrer des informations de santé, des opinions politiques, philosophiques ou religieuses, des données professionnelles confidentielles ou des informations concernant des tiers. Le traitement doit donc être conçu en presumant la présence possible de données sensibles au sens de l'article 9, même lorsque le service ne les sollicite pas.

3.3 Profil utilisateur déclaratif

Le profil est renseigné volontairement par l'utilisateur afin d'enrichir les échanges. Il est conservé simultanément dans le stockage local du navigateur et dans Firestore.

Champ	Nature
Nom affiché, parcours, profil professionnel en ligne	Identification et contexte
Texte de curriculum vitae et nom du fichier	Parcours professionnel complet
Notes de personnalité	Appréciation libre
Type de personnalité (MBTI)	Catégorisation psychologique déclarative
Cinq facteurs de personnalité (Big Five)	Scores de personnalité
Neuro-atypies déclarées	TDAH, HPI, autisme, dyslexie, dyscalculie, dyspraxie, hypersensibilité
Notes sur les neuro-atypies	Texte libre
Centres d'intérêt et notes associées	Préférences

Point de conformité majeur — données de santé

Les neuro-atypies déclarées et les notes qui les accompagnent constituent des données concernant la santé au sens de l'article 4.15 du règlement. Leur traitement est en principe interdit par l'article 9.1, sauf exception. L'exception applicable ici est le consentement explicite prévu à l'article 9.2.a. Or ces champs sont actuellement saisis dans un formulaire de profil ordinaire, sans recueil d'un consentement distinct et spécifique, et sont transmis au fournisseur de modèle de langage lors de chaque conversation. Ce point appelle une correction prioritaire.

3.4 Profil cognitif — données de profilage

Le système analyse chaque message de l'utilisateur et en extrait les faiblesses et les réflexes de raisonnement. Ces observations sont agrégées dans un document persistant.

```
users/{identifiant}/meta/cognitive
{
  counts      : { biais -> occurrences }      // 12 categories
  strengths   : { reflexe -> occurrences }    // 10 categories
  totalMessages: entier
  weeks       : { "AAAA-Sxx" : { flags, messages, wins } }
  updatedAt   : horodatage
}
```

Ces données sont réinjectées dans les instructions système des conversations suivantes. Elles constituent un profilage au sens de l'article 4.4 du règlement : une évaluation automatisée d'aspects personnels visant à analyser les performances intellectuelles de la personne.

Ce profilage ne produit toutefois pas d'effet juridique ni ne l'affecte de manière significative au sens de l'article 22 : il module la formulation des réponses, sans conditionner l'accès au service ni produire de décision. L'utilisateur peut par ailleurs le neutraliser conversation par conversation.

3.5 Données transactionnelles et techniques

Donnée	Emplacement	Finalité
Solde et historique de crédits	Supabase	Fourniture du service
Abonnement et références de paiement	Supabase	Exécution du contrat
Compteurs d'usage et de débit	Supabase et Firestore	Prévention de l'abus, application des quotas
Consentement aux communications	Supabase	Preuve de consentement
Abonnement aux notifications	Supabase	Envoi de notifications
Demandes commerciales	Supabase	Réponse aux sollicitations professionnelles
Préférences d'interface	Stockage local	Confort d'usage
Traces d'erreur applicatives	Transmises à STARIAX	Supervision technique

4. Finalités et bases légales

Finalité	Base légale	Article
Fourniture du service conversationnel	Exécution du contrat	6.1.b
Gestion du compte et authentification	Exécution du contrat	6.1.b
Facturation, abonnement et crédits	Exécution du contrat	6.1.b
Prévention de l'abus, quotas et limitation de débit	Intérêt légitime	6.1.f
Supervision technique et correction d'anomalies	Intérêt légitime	6.1.f
Profil déclaratif enrichissant les échanges	Consentement	6.1.a
Neuro-atypies déclarées (données de santé)	Consentement explicite requis	9.2.a
Profil cognitif et personnalisation	Consentement	6.1.a
Communications de relance	Consentement	6.1.a
Notifications poussées	Consentement	6.1.a
Mesure d'audience	Consentement requis	6.1.a

Écart constaté sur la mesure d'audience

L'outil de mesure d'audience est initialisé au démarrage de l'application, sans recueil préalable de consentement et sans possibilité de refus. La remontée automatique des erreurs applicatives vers la plateforme de supervision suit le même schéma. En l'absence de bandeau de consentement, ces traitements ne disposent pas d'une base légale valide au regard de l'article 82 de la loi Informatique et Libertés.

5. Destinataires et sous-traitants

Les services suivants reçoivent des données à caractère personnel. Chacun doit faire l'objet d'un contrat de sous-traitance conforme à l'article 28 du règlement.

Sous-traitant	Rôle	Données transmises	Localisation
Mistral AI	Inférence du modèle de langage	Instructions système incluant le profil déclaratif et le profil cognitif, historique complet de la conversation, contenu des pièces jointes	Union européenne (France)
Google Firebase	Authentification et base de données	Identité, conversations, profils, consentements	Hors UE (États-Unis)
Supabase	Base de données transactionnelle	Crédits, abonnements, quotas, consentements, notifications	Selon la région du projet
Vercel	Hébergement et exécution	Ensemble des requêtes et journaux techniques	Hors UE (États-Unis)
Tavily	Recherche web	Question de l'utilisateur transmise en clair	Hors UE (États-Unis)
DuckDuckGo et Wikipédia	Contexte encyclopédique	Requête en clair, sans authentification	Hors UE
Stripe	Paiement	Identifiant utilisateur, adresse électronique, données de facturation	Hors UE (États-Unis)
Resend	Courriel transactionnel	Adresse électronique, lien de réinitialisation	Hors UE (États-Unis)
Services de notification	Notifications poussées	Point de terminaison d'appareil et contenu de la notification	Selon le fabricant
STARIAX	Supervision, maintenance, versions d'essai	Identifiant utilisateur, adresse électronique, messages d'erreur, chemins consultés	Hors UE (États-Unis)

Transferts hors Union européenne

Une majorité des sous-traitants est établie aux États-Unis ou y héberge ses traitements. Ces transferts doivent être encadrés, en pratique par le cadre de protection des données UE–États-Unis lorsque le sous-traitant y est certifié, à défaut par des clauses contractuelles types assorties d'une analyse d'impact du transfert. Le choix de Mistral AI, établi en France, est à souligner favorablement : les données les plus sensibles du traitement, à savoir le contenu conversationnel et les profils, ne quittent pas l'Union pour la partie inférence.

5.1 Point de vigilance sur la recherche web

Lorsque le système détecte un besoin de recherche, la question de l'utilisateur est transmise en clair au moteur de recherche. Cette question peut contenir des informations personnelles ou sensibles. Le point d'entrée de contexte encyclopédique transmet de même la requête à des services tiers sans authentification.

6. Durées de conservation

Absence de politique de conservation

Aucune durée de conservation n'est définie, aucun mécanisme de purge automatique n'est implémenté et aucune tâche planifiée n'assure l'effacement des données devenues inutiles. En l'état, l'ensemble des données est conservé sans limite de durée, ce qui contrevient au principe de limitation de la conservation posé à l'article 5.1.e du règlement.

Les durées suivantes sont proposées à titre de recommandation et doivent être validées avant mise en œuvre :

Catégorie	Durée recommandée	Point de départ
Compte et données d'identification	Durée du compte, puis 30 jours	Suppression du compte
Conversations	Durée du compte, ou suppression à l'initiative de l'utilisateur	—
Profil déclaratif et neuro-atypies	Durée du compte, retrait du consentement possible à tout moment	—
Profil cognitif	Durée du compte	—
Compteurs de quota et de débit	13 mois	Dernière activité
Données de facturation	10 ans	Obligation comptable
Preuve de consentement	5 ans après retrait	Retrait du consentement
Conversations partagées	Jusqu'à révocation par l'auteur	—
Traces techniques et journaux	6 à 12 mois	Enregistrement
Comptes anonymes inactifs	6 mois	Dernière connexion

7. Droits des personnes

Droit	Article	État actuel
Information	13 et 14	Partiel — la politique de confidentialité renvoie aux conditions générales
Accès	15	Partiel — seul le profil déclaratif est exportable
Rectification	16	Assuré — le profil est modifiable
Effacement	17	Incomplet — voir ci-dessous
Limitation	18	Non implémenté
Portabilité	20	Partiel — export du profil et des conversations en Markdown, PDF et JSON
Opposition	21	Partiel — désabonnement des communications possible
Décision automatisée	22	Sans objet — le profilage ne produit pas d'effet juridique
Retrait du consentement	7.3	Partiel — neutralisation du profil par conversation

7.1 Écarts sur le droit à l'effacement

- **Aucune suppression de compte** — la fonction d'effacement d'un compte n'est implémentée nulle part. Un utilisateur ne peut pas obtenir la suppression de ses données par un moyen automatisé.
- **Effacement partiel seulement** — la suppression d'une conversation et d'un dossier est possible. Le profil cognitif, les compteurs d'usage, la preuve de consentement et l'ensemble des données transactionnelles ne disposent d'aucun mécanisme d'effacement.
- **Conversations partagées non révocables** — le document de partage ne contient pas l'identifiant du propriétaire, alors que la règle de sécurité l'exige pour autoriser la suppression. Une conversation rendue publique par lien ne peut donc pas être retirée par son auteur. Cet écart est le plus critique du présent recensement.
- **Accumulation locale** — les clés de progression du défi quotidien s'accumulent indéfiniment dans le stockage du navigateur, sans purge.

8. Mesures de sécurité

8.1 Mesures en place

Mesure	Description
Dérivation de l'identité	L'identifiant utilisateur provient systématiquement du jeton vérifié côté serveur, jamais de la requête
Refus par défaut en production	Le service de conversation refuse de répondre si la vérification d'identité n'est pas active
Cloisonnement Firestore	Les documents d'un utilisateur ne sont accessibles qu'à lui ; une règle terminale refuse le reste
Refus total sur la base transactionnelle	Sécurité au niveau des lignes activée sans politique : seul le serveur accède aux tables
Révocation des procédures	Les procédures stockées ne sont exécutables que par le rôle de service
Confinement des secrets	Aucune clé sensible dans le paquet client, vérifié par recherche dans les fichiers construits
Intégrité des paiements	Vérification de la signature des événements sur le corps brut de la requête
Anti-énumération	La réinitialisation de mot de passe ne révèle pas l'existence d'une adresse
Anti-énumération du statut d'essai	La résolution des versions d'essai passe par un relais serveur, empêchant l'interrogation du statut d'autrui
Chiffrement en transit	Communications en HTTPS de bout en bout

8.2 Mesures absentes

Manque	Conséquence	Recommandation
Chiffrement applicatif	Conversations, curriculum vitae, notes de santé et profil cognitif stockés en clair chez les hébergeurs	Évaluer un chiffrement des champs relevant de l'article 9
Journalisation des accès	Impossibilité de tracer un accès administrateur aux données	Mettre en place une journalisation des accès privilégiés
Politique de purge	Conservation sans limite	Implémenter des tâches d'effacement automatique
Contrôle d'origine	Origines autorisées sans restriction sur tous les points d'entrée	Restreindre à une liste d'origines connues
Point d'entrée de diagnostic	Divulgaration publique de l'état de configuration du service de courriel	Supprimer, conformément à la mention portée dans le code
Analyse d'impact	Traitement à risque non évalué formellement	Conduire une analyse d'impact — voir section suivante

9. Nécessité d'une analyse d'impact

L'article 35 du règlement impose une analyse d'impact relative à la protection des données lorsque le traitement est susceptible d'engendrer un risque élevé. Trois critères des lignes directrices du Comité européen de la protection des données sont réunis, ce qui rend l'analyse nécessaire :

- **Évaluation ou notation** — le profil cognitif évalue les performances intellectuelles de la personne et lui attribue un rang.
- **Données sensibles** — les neuro-atypies déclarées relèvent des données de santé, et le contenu conversationnel peut en contenir davantage.
- **Usage innovant** — le recours à un modèle de langage pour analyser le raisonnement d'une personne dans la durée constitue un usage nouveau.

Deux critères suffisent en principe à déclencher l'obligation. L'analyse d'impact doit être conduite avant toute ouverture large du service.

10. Synthèse des écarts et plan de mise en conformité

Les écarts sont classés par criticité décroissante. La criticité combine la gravité de l'atteinte potentielle aux droits des personnes et la probabilité de sa survenance.

N°	Écart	Criticité	Action recommandée
1	Conversations partagées non supprimables par leur auteur (champ propriétaire absent)	Critique	Ajouter le champ propriétaire à la charge écrite et prévoir la révocation d'un partage
2	Absence de suppression de compte et de données	Critique	Implémenter un effacement complet couvrant Firebase, Firestore et la base transactionnelle
3	Données de santé traitées sans consentement explicite distinct	Critique	Isoler les champs de neuro-atypies derrière un consentement spécifique et révocable
4	Absence de durées de conservation et de purge	Élevée	Définir une politique et implémenter les tâches d'effacement
5	Mesure d'audience et remontée d'erreurs sans consentement	Élevée	Mettre en place un bandeau de consentement et conditionner l'initialisation
6	Politique de confidentialité inexistante en tant que telle	Élevée	Rédiger un document distinct des conditions générales, conforme aux articles 13 et 14
7	Analyse d'impact non réalisée	Élevée	Conduire l'analyse avant ouverture large
8	Absence d'export global des données	Moyenne	Étendre l'export existant à l'ensemble des données détenues
9	Délégué à la protection des données non désigné	Moyenne	Évaluer l'obligation au regard de l'article 37 et désigner le cas échéant
10	Point d'entrée de diagnostic exposé publiquement	Moyenne	Supprimer le fichier
11	Table de demandes commerciales sans politique de sécurité documentée	Moyenne	Déclarer la table et activer la sécurité au niveau des lignes
12	Collections héritées accessibles à tout compte authentifié	Moyenne	Retirer les règles devenues sans objet
13	Contrats de sous-traitance à formaliser	Moyenne	Recenser et contractualiser les dix sous-traitants identifiés
14	Absence de chiffrement applicatif des données sensibles	Faible	Évaluer l'opportunité au regard du risque résiduel

10.1 Séquencement proposé

- **Immédiat** — écarts 1, 10 et 11 : corrections techniques circonscrites, réalisables sans arbitrage produit.
- **Avant ouverture large** — écarts 2, 3, 5, 6 et 7 : ils conditionnent la licéité du traitement et ne peuvent être différés au-delà d'un usage restreint.
- **À planifier** — écarts 4, 8, 9, 12 et 13 : mise en conformité structurelle.
- **À évaluer** — écart 14 : arbitrage coût et bénéfice au regard du risque résiduel.

11. Historique du document

Version	Date	Objet
1.0	19 juillet 2026	Émission initiale — état des lieux et recensement des écarts